

Access controls worksheet

Payroll incident investigation. Authorization and authentication review.

Incident summary

A fraudulent payroll entry routed a payment to an unknown bank account (FAUX_BANK). The event log source IP correlated to a single directory record: a contractor whose engagement had ended nearly four years before the incident.

Notes	Issues	Recommendations
Who caused this incident? The account Legal\Administrator, which cross-references to Robert Taylor Jr., a legal attorney engaged as a contractor. Source IP 152.207.255.255 matched his directory record exactly. When did it occur? 10/03/2023 at 8:29:57 AM. What device was used? Host Up2-NoGud, generating the entry: Payroll event added. FAUX_BANK. Key finding The contractor end date in the directory was 27 December 2019, roughly four years before the incident. The account was still active.	Access level The account held Admin authorization, a privilege level a contractor role should never have required. Least-privilege violation. Should the account be active? No. The contractor engagement ended in December 2019, but the account was never deprovisioned, leaving a standing admin credential available for abuse. Offboarding and account-management failure.	Technical Enforce least privilege by scoping contractor accounts to only what the role requires. Require MFA on any account able to create or modify payment records. Operational Tie account deprovisioning to the contractor end date so accounts disable automatically. Run periodic access reviews to catch orphaned accounts. Managerial Apply separation of duties and an approval step on payment-destination changes, so no single account can both create and finalize a new payee. NIST 800-53 mapping AC-6 least privilege, AC-2 account management, PS-4 and PS-5 personnel termination and transfer.